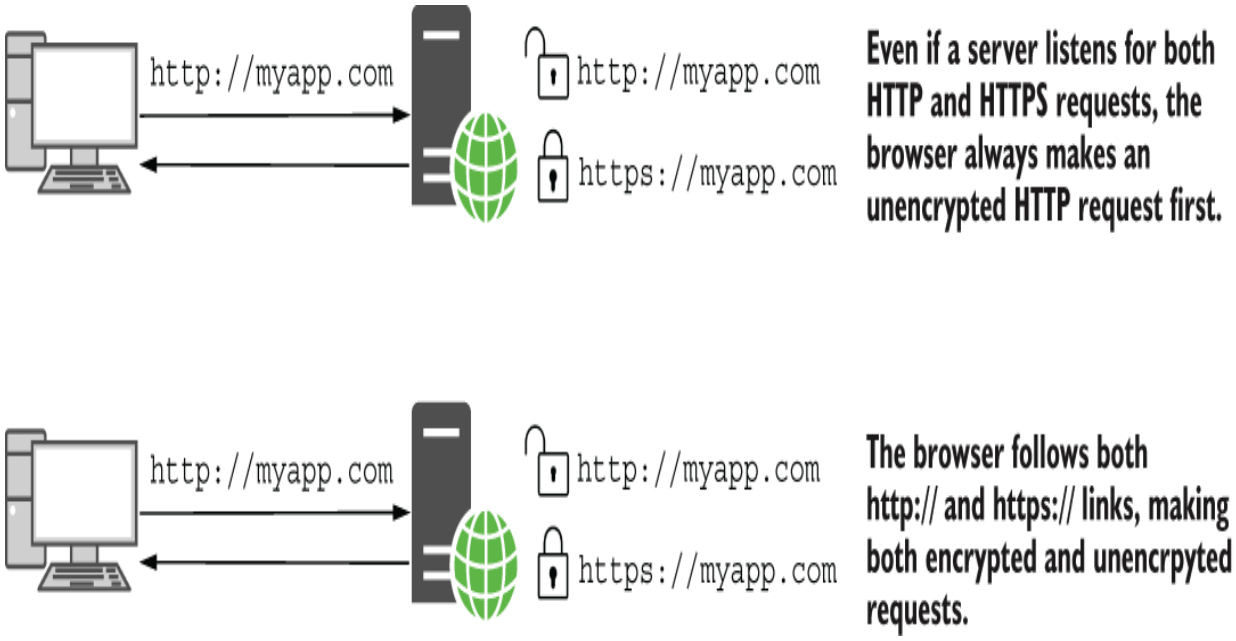


Figure 28.6 When you type in a URL, browsers load the app over HTTP by default. Depending on the links returned by your app or the URLs entered, the browser may make HTTP or HTTPS requests.

One partial mitigation (and a security best practice) is to add HTTP Strict Transport Security headers to your responses.

DEFINITION HTTP Strict Transport Security (HSTS) is a specification (https://www.rfc-editor.org/rfc/rfc6797) for the `Strict-Transport-Security` header that instructs the browser to use HTTPS for all subsequent requests to your application. The HSTS header can be sent only with responses to HTTPS requests. It is also relevant only for requests originating from a browser; it has no effect on server-to-server communication or on mobile apps.

After a browser receives a valid HSTS header, the browser stops sending HTTP requests to your app and uses only HTTPS instead, as shown in figure 28.7. Even if your app has an http:// link or the user enters http:// in the URL